

Septembre 2026

Parcours PASI – Piloter et animer la sécurité informatique

V.1.0

Lancement de la formation PASI



GUILLAUME CARAYON

Consultant formateur cybersécurité



OIDANEOS

Présentation de la formation PASI

Présentation de la formation PASI

Présentation des modules et sous-module associé

	Module	Sous-module
1	Fondamentaux techniques et règlementaires	1.1 – Fondamentaux de la SSI et réseaux 1.2 – Règlementation
2	Pilotage stratégique de la cybersécurité	2.1 – Gouvernance et stratégie de la sécurité 2.2 – Gestion des prestataires et conformité
3	Analyse des risques et contrôles	3.1 – Analyse et évaluation des risques 3.2 – Mise en œuvre d'actions de contrôle
4	Réponse aux incidents et sensibilisation	4.1 – Organisation et coordination des réponses à incident 4.2 – Sensibilisation et formation des équipes

Présentation de la formation PASI

Module 1 – Fondamentaux techniques et réglementaires

1.1 – Fondamentaux de la sécurité des SI et des réseaux

Objectifs :



- Connaître les principales failles et menaces des SI
- Connaître le rôle des différents équipements de sécurité
- Proposer des solutions de sécurisation
- Mettre en œuvre les principaux moyens de sécurisation des systèmes et réseaux
- Capitaliser des informations dans le cadre d'une veille

1. Introduction à la sécurité des SI

2. Les principales menaces et failles

3. Architecture et équipements de sécurité

4. Sécurisation des systèmes et réseaux

5. Sécurité des échanges et des données

6. Veille technologique et réglementaire

7. Cas pratique : sécurisation d'un environnement réseau et veille associée

Présentation de la formation PASI

Module 1 – Fondamentaux techniques et réglementaires

1.2 – Règlementation (RGPD, ISO, conformité)

Objectifs :



- Comprendre les enjeux relatifs à la protection des données personnelles avec le RGPD
- Comprendre les normes adaptées au système d'information (27001) et à la gestion des risques (27005)
- Identifier les risques liés aux données personnelles dans le SI
- Analyser et contribuer à définir la politique de sécurité

1. Introduction au RGPD

2. La réglementation et la sécurité de l'information

3. Normes et conformité ISO (27001/27005)

4. Cas pratique: analyse de conformité RGPD/ISO pour un SI



Présentation de la formation PASI

Module 2 – Pilotage stratégique de la cybersécurité

2.1 – Gouvernance et stratégie de la sécurité

Objectifs :



- Mettre en œuvre la politique de cybersécurité
- Comprendre les enjeux d'une PSSI
- Maîtriser les fondamentaux de la gestion de projet

1. Introduction à la gouvernance de la sécurité

2. Élaborer une stratégie de cybersécurité

3. Définir et formaliser la PSSI

4. Sensibilisation et communication interne

5. Indicateurs et tableaux de bords sécurité

6. Cas pratique : concevoir la PSSI et le tableau de bord d'une entreprise fictive



Présentation de la formation PASI

Module 2 – Pilotage stratégique de la cybersécurité

2.2 – Gestion des prestataires et conformité

Objectifs :



- Identifier les obligations et les risques liés à la sous-traitance
- Rédiger des clauses types et analyser le contrat fournisseur
- Construire un plan d'audit interne/externe
- Gérer les non-conformités, plans d'actions, sanctions
- Mettre à jour la conformité selon NIS2, RGPD, ISO 27001

1. Gestion des prestataires et des sous-traitants

2. Clauses contractuelles de sécurité

3. Pilotage des audits et évaluations

4. Gestion des incidents contractuels

5. Veille réglementaire et conformité continue

6. Cas pratique : auditer un prestataire et contractualiser selon la PSSI



Présentation de la formation PASI

Module 3 – Analyse des risques et contrôles

3.1 - Analyse et évaluation des risques

Objectifs :



- Maîtriser les fondamentaux de la gestion des risques
- Comprendre les différents risques, menaces, techniques d'attaques et vulnérabilités
- Maîtriser la méthode d'analyse de risque EBIOS RM
- Maîtriser le vocabulaire et les concepts
- Analyser, cartographier et évaluer les risques de cybersécurité
- Identifier les activités critiques

1. Introduction à la gestion des risques cyber

2. Cadres normatifs et méthodologies (ISO 27005, EBIOS RM)

3. Identification des actifs et des menaces

4. Évaluation des vulnérabilités et scénarios d'attaques

5. Mesure et hiérarchisation des risques

6. Élaboration de la cartographie des risques

7. Réaliser une analyse de risques complètes pour un système d'information donné

Présentation de la formation PASI

Module 3 – Analyse des risques et contrôles

3.2 – Mise en œuvre d'actions de contrôle

Objectifs :



- Assurer le suivi des actions mises en place dans le cadre de la démarche de cybersécurité
- Connaître les moyens de contrôle et de maintien du niveau de sécurité
- Organiser et tracer les actions de contrôle

1. Plan de traitement et priorisation des actions

2. Pilotage et indicateurs de suivi

3. Contrôles et audits internes de sécurité

4. Suivi des risques résiduels et amélioration continue

5. Cas pratique : rédiger un rapport de contrôle cybersécurité



Présentation de la formation PASI

Module 4 – Réponse aux incidents et sensibilisation

4.1 – Organisation et coordination des réponses à incident

Objectifs :



- Mettre en place un processus de gestion de crise
- Evaluer les risques et enjeux de la reprise après sinistre et de la continuité de service
- Formaliser et mettre en oeuvre des plans (réponse à incident, PCA / PRA)
- Connaître les méthodes et outils pour choisir le type de site de reprise et réussir les projets
- Sélectionner les technologies, architectures et solutions les plus pertinentes

1. Introduction à la gestion de crise cyber

2. Organisation de la réponse à incident

3. Coordination des équipes et procédures d'escalade

4. Plan de continuité et reprise d'activité (PCA/PRA)

5. Cas pratique : simulation d'un incident majeur et coordination des équipes



Présentation de la formation PASI

Module 4 – Réponse aux incidents et sensibilisation

4.2 – Sensibilisation et formation des équipes

Objectifs :



- Identifier les acteurs et les informations pertinentes à communiquer sur la sécurité informatique
- Vulgariser les différentes menaces informatiques et leurs conséquences auprès des utilisateurs
- Concevoir des documents adaptés aux enjeux de communication visés
- Appuyer les services RH dans l'élaboration du plan de formation des professionnels des SI

1. Introduction à la culture cybersécurité

2. Diagnostic du niveau de maturité cyber

3. Conception d'un plan de formation interne

4. Outils et méthodes de sensibilisation

5. Animation et communication interne

6. Évaluation et amélioration continue

7. Cas pratique : élaborer un plan complet de formation et sensibilisation cyber

Quelques principes associés à la SSI

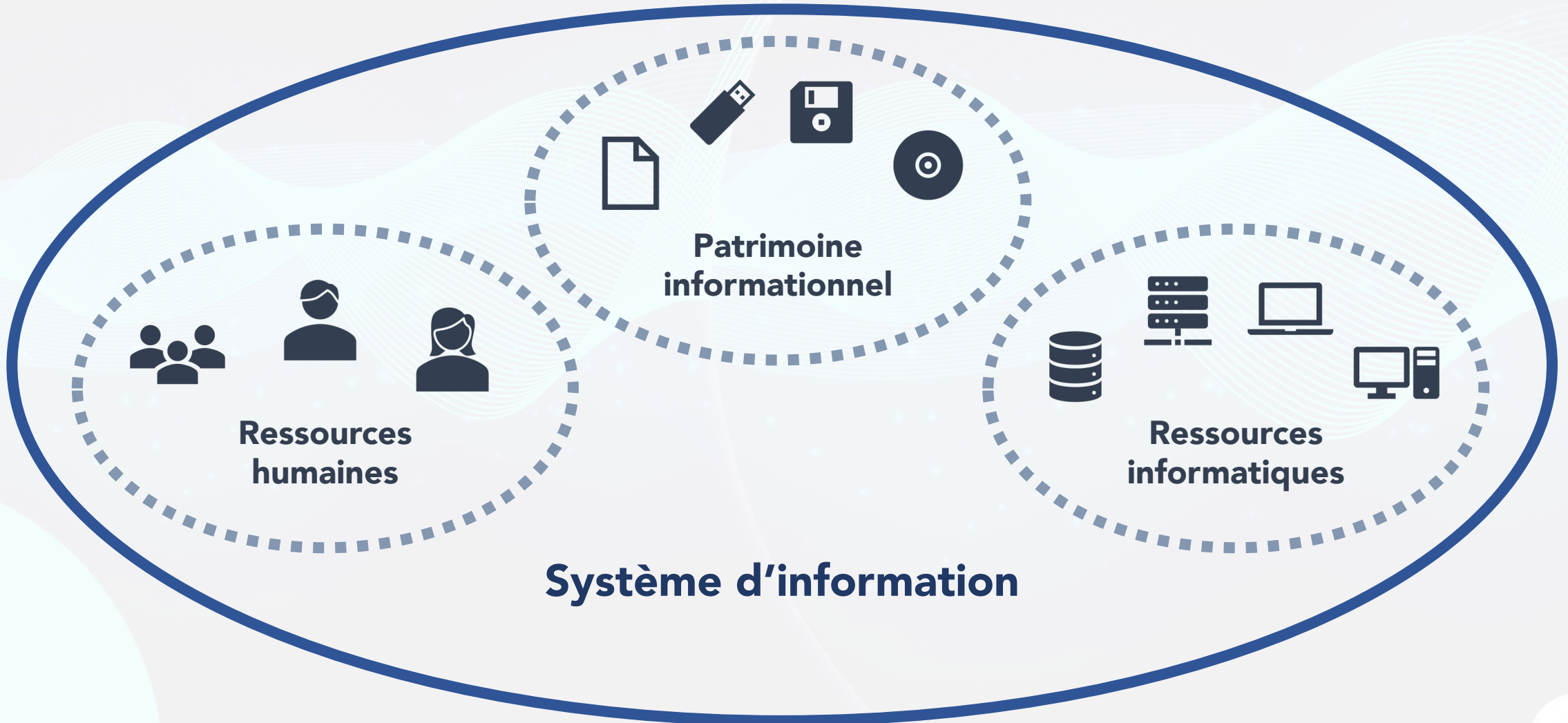
La notion de système d'information



?

Qu'est-ce qu'un système d'information ?

La notion de système d'information



La notion de système d'information

Système d'information

Ensemble organisé de ressources permettant de traiter et diffuser de l'information en fonction des objectifs d'une organisation



Système informatique

Réseaux, serveurs, postes de travaux, logiciels, applications, BDD... faisant partie du système d'information. L'informatique nomade en fait partie



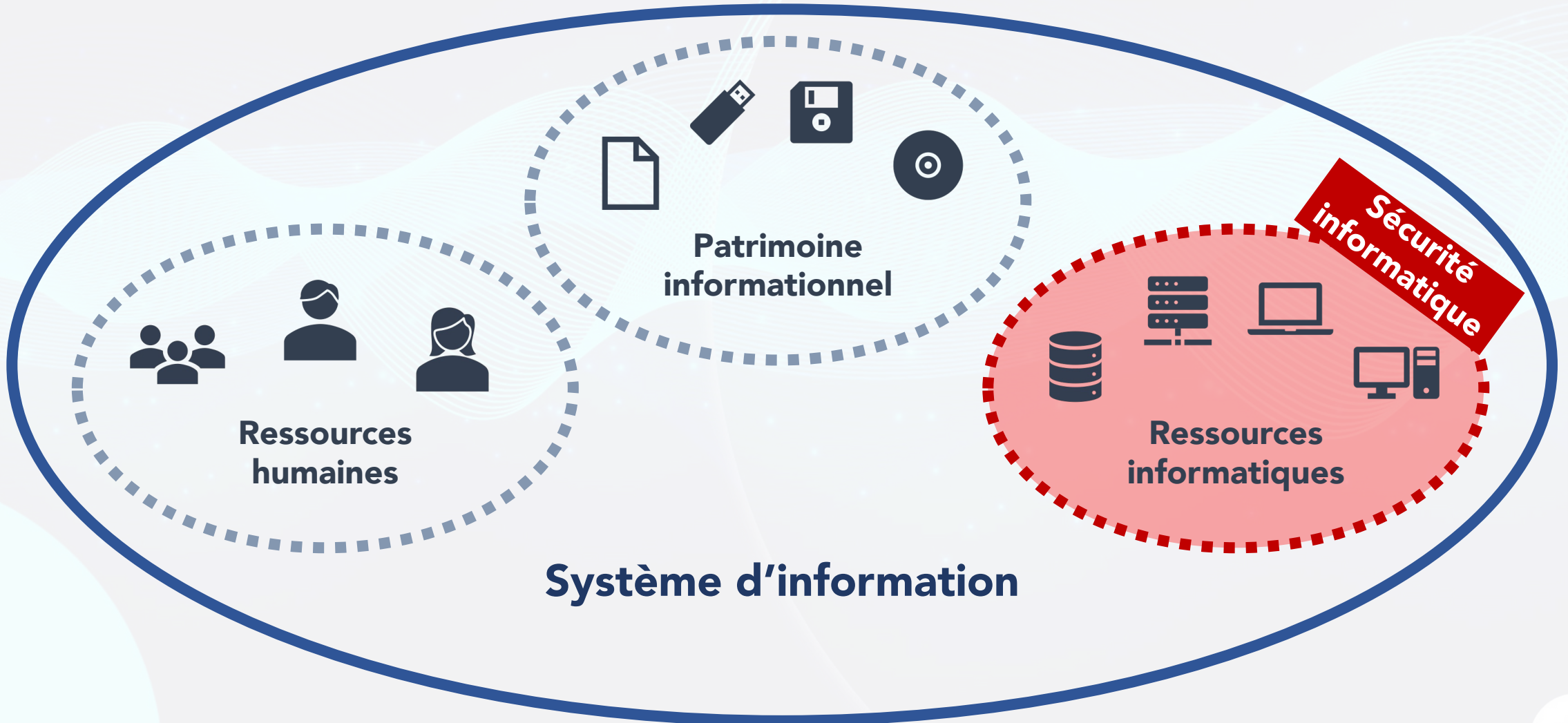
La notion de système d'information



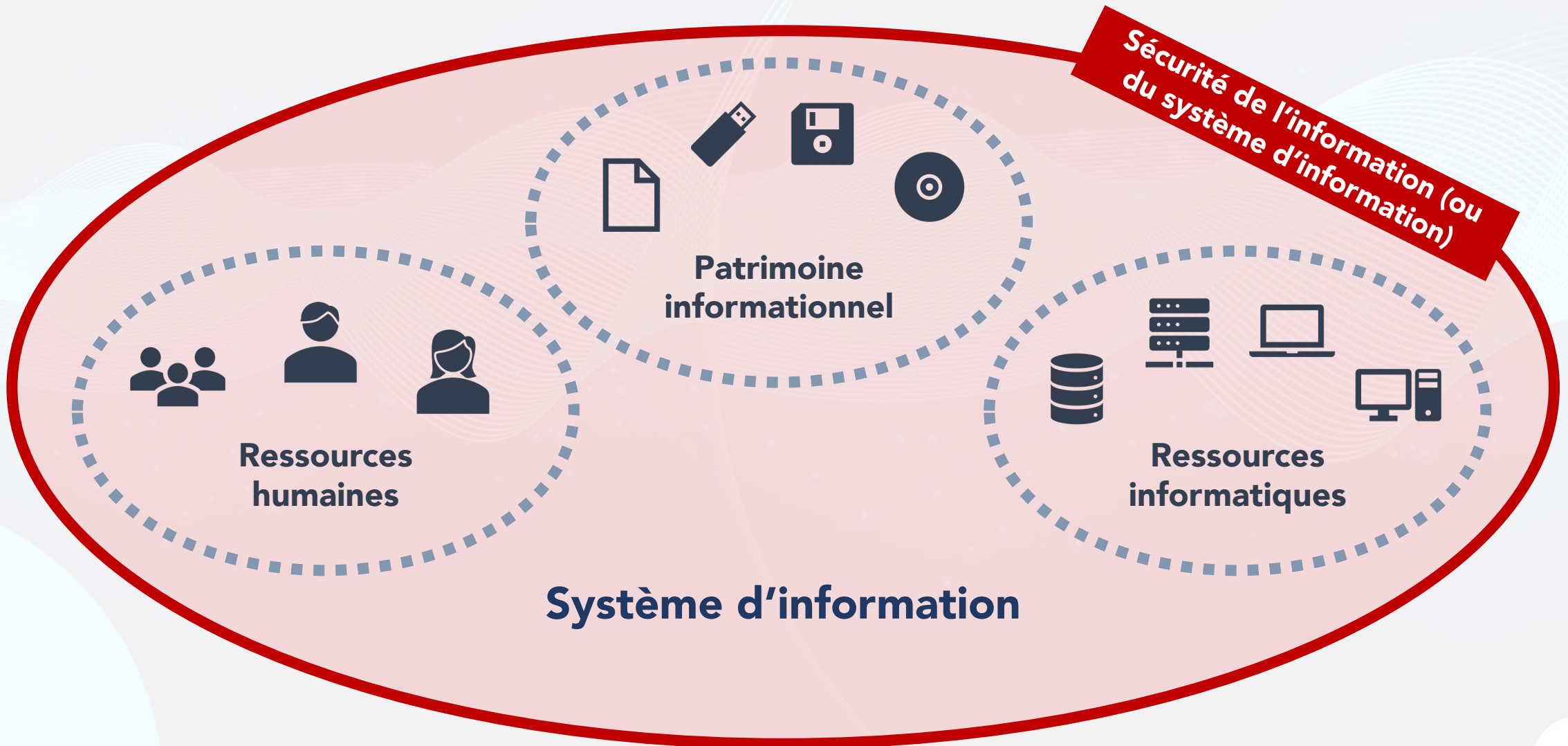
?

Quelle différence entre **sécurité informatique**, **sécurité de l'information** (ou sécurité du système d'information) et **cybersécurité** ?

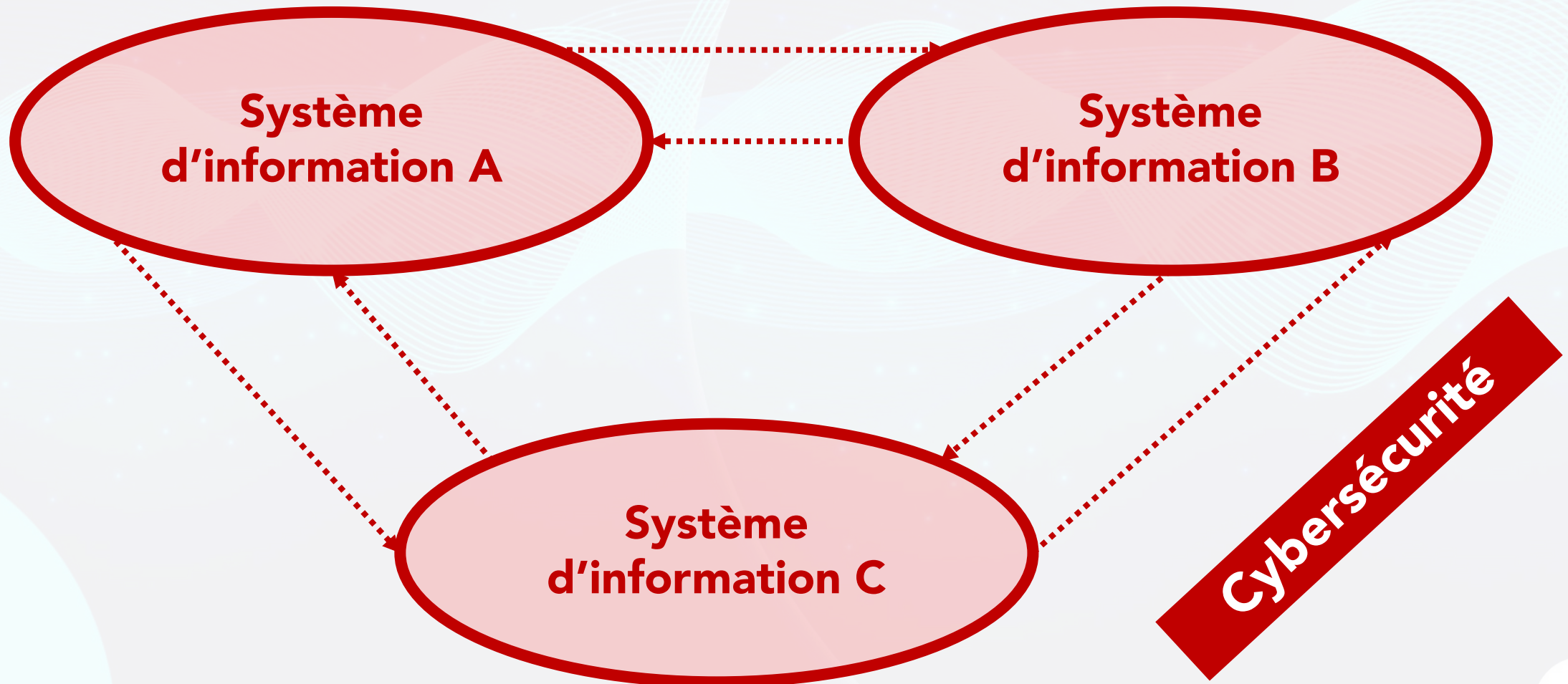
La notion de système d'information



La notion de système d'information



La notion de système d'information



La notion de système d'information

Sécurité informatique

Ensemble des règles, procédures techniques et outils utilisés pour préserver la confidentialité, l'intégrité et la disponibilité des données traitées par les systèmes informatiques.

Sécurité de l'information (*sécurité du système d'information*)

La sécurité de l'information a pour objectif de protéger la confidentialité, l'intégrité et la disponibilité des informations de n'importe quel type et de n'importe quelle origine. La sécurité de l'information est menacée par des actes volontaires mais aussi des actes involontaires, des dysfonctionnements techniques ou encore des menaces environnementales...

Cybersécurité

Extension de la sécurité informatique au cyberspace : Internet et réseaux comparables, ainsi que les communications, les applications, traitements et informations traitées.

Les critères de sécurité DICT

Propriété d'être accessible et utilisable
à la demande par une entité autorisée
(ISO 27000, 3.7)

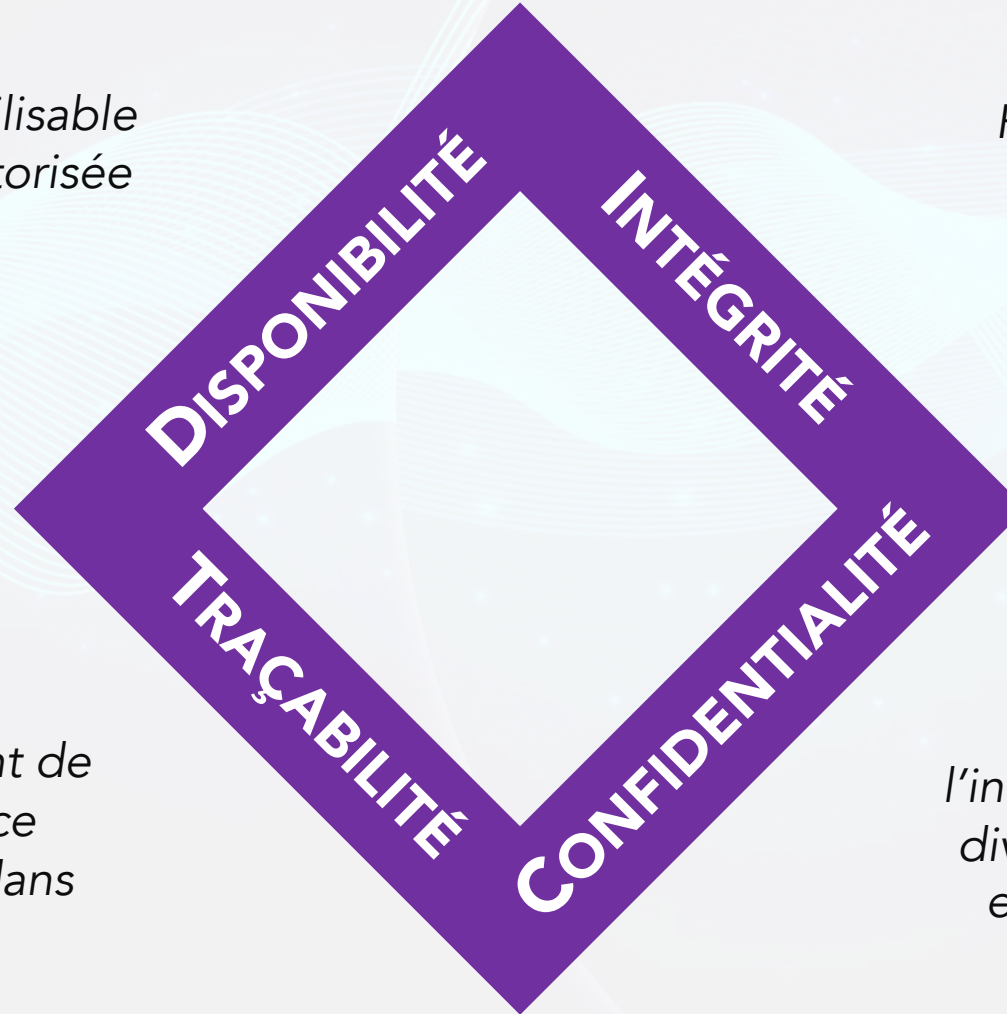


Authentification



**Non-
répudiation**

Propriété d'un bien permettant de
retrouver, avec une confiance
suffisante, les circonstances dans
lesquelles ce bien évolue
(ANSSI, CyberEdu)



Propriété d'exactitude et de
complétude
(ISO 27000, 3.6)

Propriété selon laquelle
l'information n'est pas diffusée ni
divulguée à des personnes, des
entités ou des processus non
autorisés
(ISO 27000, 3.10)



Les motivations principales des cyber-attaquants

Gain financier



Idéologie



Déstabilisation



**Agression pour
obtenir des
capacités d'attaque
additionnelles**



Quels sont les principaux vecteurs d'attaques ?



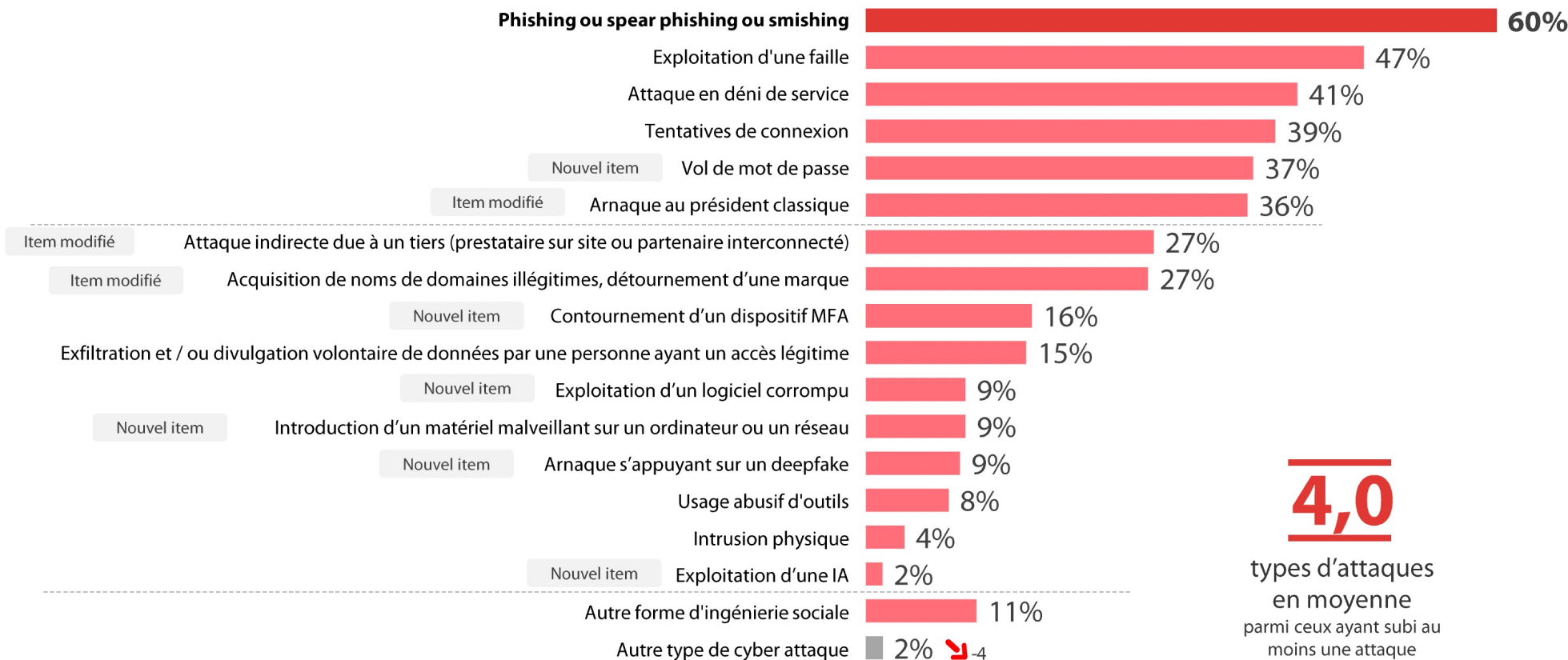
Avec en moyenne 4 vecteurs, le phishing reste en tête des attaques, suivi par l'exploitation d'une faille existante. Les stratégies d'attaque sont similaires à l'année précédente.

Q5A. Parmi les vecteurs d'attaques suivants, lesquels ont impacté votre entreprise au cours des 12 derniers mois ?

Base : ont constaté une attaque - plusieurs réponses possibles



47% des entreprises ont subi au moins une cyberattaque en 2023



Quels sont leurs impacts ?



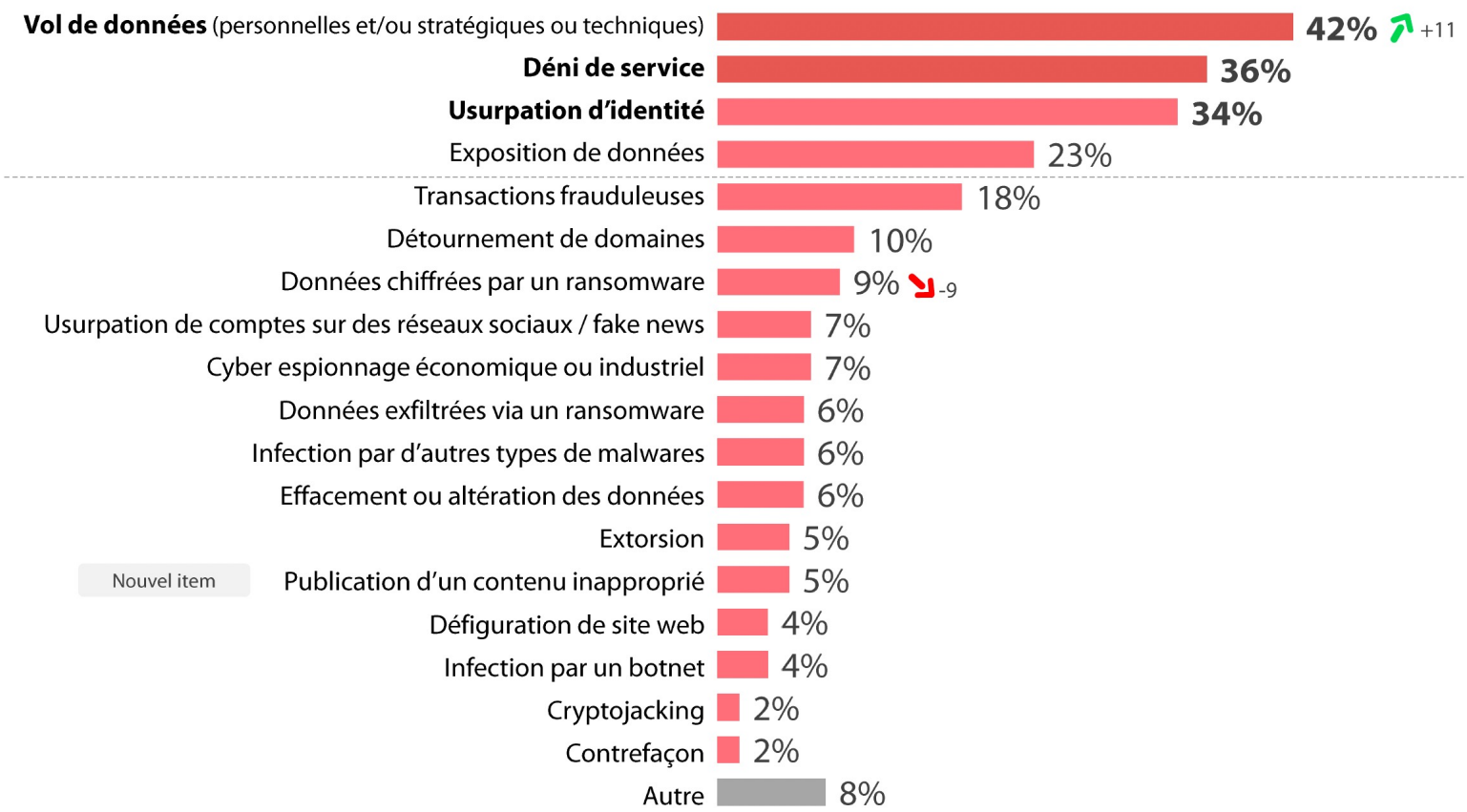
Le vol de données demeure en tête des conséquences de ces attaques et gagne même du terrain. Le déni de service et l'usurpation d'identité sont ensuite constatés par plus d'1/3 des entreprises. A noter, la baisse des données chiffrées par un ransomware.



Q5B. Et quelles ont été les conséquences de cette/ces attaque(s) ?

Base : ont constaté une attaque - plusieurs réponses possibles

47% des entreprises ont subi au moins une cyberattaque en 2023



Hacktivistes

- **Motivation idéologique :**
 - Révélation de scandales ou de mauvaises pratiques
 - Décrédibilisation d'une structure, d'une personne ou d'une organisation
 - Soutien à une cause
- **Actions possibles :**
 - Dysfonctionnement des systèmes pour attirer l'attention (DoS, DDoS)
 - Publication de messages idéologiques (défacement)
 - Publication d'informations volées
 - Déstabilisation des cibles (doxing)
 - Contournement des censures : geobombing, astroturfing, sites miroirs



Cybercriminels

- **Motivation financière**

- Menaces sur les particuliers : vol et revente de données de compte, fraude à la carte bancaire, demande de rançon après blocage de l'ordinateur, chantage à la webcam, arnaques de toute sorte
- Menaces sur les organisations privées et publiques
 - Vol de secret industriel ou stratégique
 - Fraude au président
 - Piratage de réseau d'une banque
 - Piratage de distributeurs de billets
 - Demandes de rançons



États

- **Espionnage**
- **Déstabilisation**
 - Désinformation classique
 - Vol de données réelles pour alimenter une campagne de désinformation et lui donner une grande crédibilité
 - Interruption du fonctionnement, voire sabotage d'organisations publiques comme privées
 - Sabotage d'infrastructures critiques
- **Appui aux opérations militaires**
 - Piégage des systèmes numériques à la source
 - Pré-positionnement sur les systèmes numériques des cibles
 - Ecoute et captation des données



Écosystème des attaquants



Etape 1

Production d'outils
malveillants

Groupes spécialisés dans
le développement de
programmes malveillants
et virus informatiques



Etape 2

Exploitation et
commercialisation

Groupes qui exploitent
les outils et
commercialisent leurs
services (HaaS) pour
réaliser des attaques
informatiques



Etape 3

Hébergement

Des hébergeurs
(malhonnêtes ou victimes)
stockent les contenus
malveillants



Etape 4

Revente des
données volées

Groupes qui revendent
les données volées



Etape 5

Collecte de
l'argent

Des intermédiaires
financiers collectent
l'argent et s'appuient sur
des réseaux de mules



Écosystème des attaquants

- Revendeurs d'accès initiaux (initial access broker)
- Hébergeurs véreux (bulletproof) et systèmes d'anonymisation
- Plateforme de rançonnage
- Revendeurs ou blanchisseurs de données
- Blanchisseurs d'argent
- Chercheurs de failles, achat et revente des failles
- Créateurs d'outils pour exploiter les failles



La cyber killchain



Les outils complémentaires à la cyber kill chain de Lockheed Martin



Le modèle alternatif de
FireEye



La matrice MITRE
ATT&CK

[illegible]

Les standards élémentaires en matière de cybersécurité



Les réglementations en matière de cybersécurité



Dans le détail, c'est la réglementation NIS2 qui impacte principalement les entreprises, loin devant DORA et le Cyber Resilience Act. En parallèle, le Cyberscore reste minoritaire.



Nouvelle question en 2024

Q47 : Et par quelle(s) réglementation(s) cyber votre société est-elle impactée ?

Base : votre société est impactée par une ou plusieurs réglementations cyber (hors RGPD) - plusieurs réponses possibles

